

网络与信息安全技术

顾辰

guchen@hfut.edu.cn



教学内容

- 第1章 信息安全概述
- 第2章 对称密码学
- 第3章 非对称密码学
- 第4章 消息认证
- 第5章 安全技术应用
- 第6章 安全前沿技术



教学内容

□ 能够学到

➤ 密码学术语，密码学主流算法，身份认证，现实中涉及安全的应用

□ 不能学到

➤ 密码学数学基础（群论等）

课外教材

- [1] 刘建伟、王育民，网络安全-技术与实践，清华大学出版社
- [2] 蔡晶晶,李炜，网络空间安全导论，机械工业出版社
- [3] 刘建伟. 网络安全概论. 电子工业出版社.
- [4] William Stallings. 密码编码学与网络安全-原理与实践. 电子工业出版社.



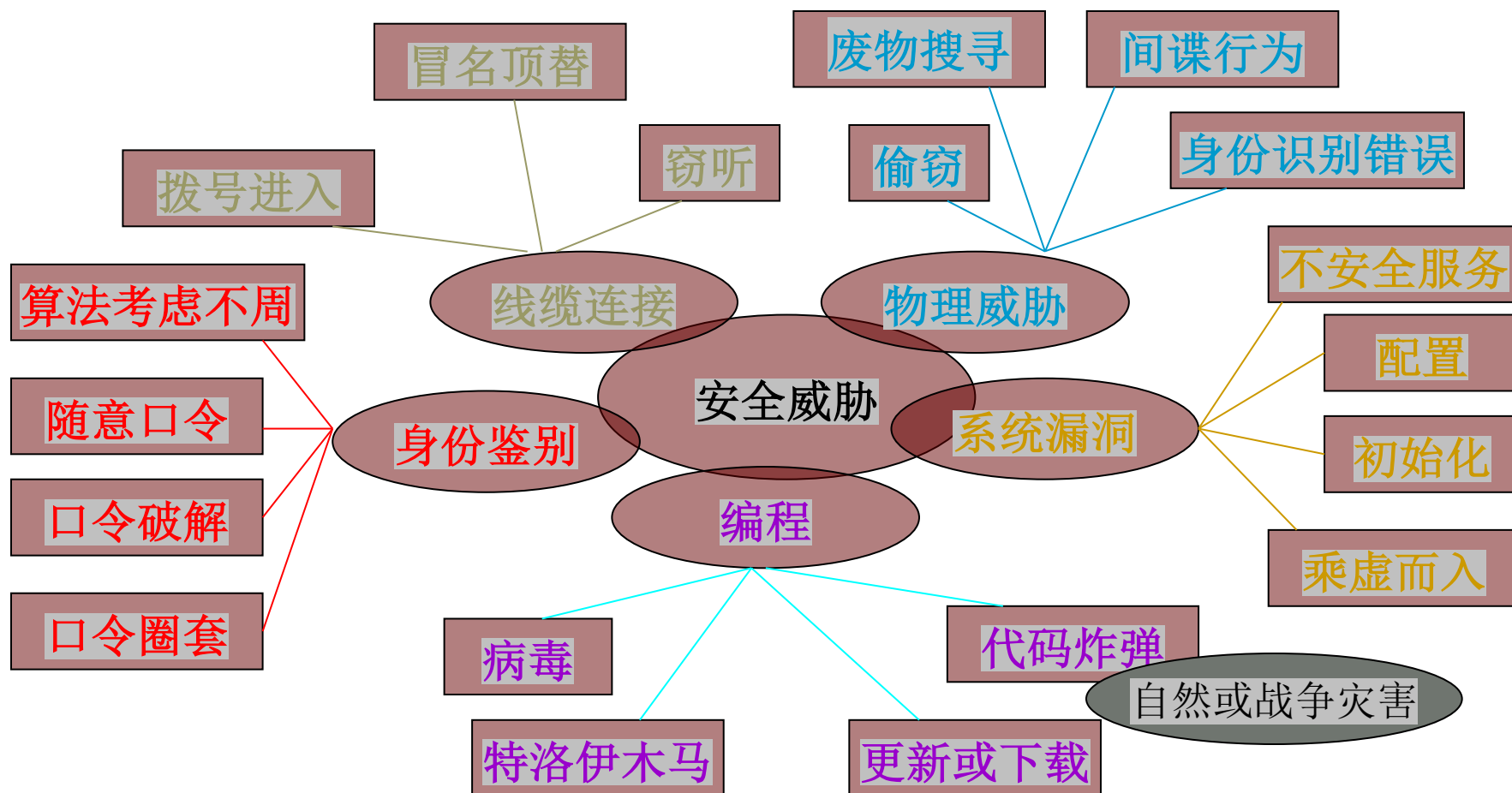
1 信息安全

- 信息安全，ISO（国际标准化组织）的定义为：为数据处理系统建立和采用的技术、管理上的安全保护，为的是保护计算机硬件、软件、数据不因偶然和恶意的原因而遭到破坏、更改和泄露。
- WannaCry勒索病毒
https://www.bilibili.com/video/BV11y4y1m79z/?spm_id_from=333.337.search-card.all.click&vd_source=4c1e046080d396b885383035c58cc631
- 震网病毒
➤ https://www.bilibili.com/video/BV1TK411J7tG/?spm_id_from=333.337.search-card.all.click&vd_source=4c1e046080d396b885383035c58cc631
- 个人隐私
➤ https://www.bilibili.com/video/BV175411a71j/?spm_id_from=333.1387.homepage.video_card.click&vd_source=4c1e046080d396b885383035c58cc631

1 信息安全的安全隐患

- ❑ 假冒：不合法的用户侵入到系统，通过输入账号等信息冒充合法用户从而窃取信息的行为
- ❑ 身份窃取：合法用户在正常通信过程中被其他非法用户拦截
- ❑ 数据窃取：非法用户截获通信网络的数据
- ❑ 否认：通信方在参加某次活动后却不承认自己参与
- ❑ 拒绝服务：合法用户在提出正当的申请时，遭到了拒绝或者延迟服务
- ❑ 非访问授权：访问没有权限的文件

1 安全威胁的分类



1 安全目标

- **机密性 (Confidentiality)**：私密的或机密的信息不能透露给非授权的个体。
- **完整性 (Integrity)**：信息和程序只能按指定的且授权的方式修改。
- **可用性 (Availability)**：系统必须及时地工作，不能拒绝向授权用户提供服务。
- **授权性**：授权能够明确用户的权限，这决定了用户能否对网络信息系统进行访问，是用户进一步操作各项信息数据的前提。
- **抗抵赖性**：操作用户无法否认自身在网络上的各项操作，整个操作过程均能够被有效记录。

1 安全防护策略

- 加强安全防护意识：提高自身安全意识，拒绝下载不明软件，禁止点击不明网址、提高账号密码安全等级、禁止多个账号使用同一密码等，加强自身安全防护能力。
- 科学采用数据加密技术：它能够最大限度的避免信息泄露的风险，从而保护信息安全
- 提高硬件质量：硬件系统在考虑安全性的基础上，还必须重视硬件的使用年限问题，硬件作为计算机的重要构成要件，其具有随着使用时间增加其性能会逐渐降低的特点，用户应注意这一点，在日常中加强维护与修理。
- 加强计算机入侵检测技术的应用：入侵检测主要是针对数据传输安全检测的操作系统，通过IDS（入侵检测系统）入侵检测系统的使用，可以及时发现计算机与网络之间异常现象，通过报警的形式给予使用者提示。
- 其他措施：加强计算机网络密码设置、安装系统漏洞补丁程序等

1 安全事件举例

□ 利用计算机进行经济犯罪

➤ 2016年2月，黑客企图从孟加拉国一家银行窃取10亿美元

https://www.bilibili.com/video/BV1TT4y1E7KF/?spm_id_from=33.337.search-card.all.click&vd_source=4c1e046080d396b885383035c58cc631

1.1 安全事件举例

□ NVIDIA信息泄露事件

➤ https://www.bilibili.com/video/BV1La411h7bS/?spm_id_from=333.788.recommend_more_video.-1

□ 阿里云香港地区服务器宕机事件

➤ https://www.bilibili.com/video/BV1MG4y1P75D/?spm_id_from=333.337.search-card.all.click&vd_source=4c1e046080d396b885383035c58cc631

1.2 需要理解的几个关系

- 信息安全和网络安全、数据安全的关系？
- 网络安全是以网络为主要的安全体系，主要涉及网络安全域、防火墙、网络访问控制、抗DDoS等场景，更多是指向整个网络空间的环境。网络安全的客观概念是网络系统包括使用网络过程中网络信息的产生、储存、传输和使用都不受任何威胁与侵害，能正常地实现资源共享功能。
- 数据安全是以数据为中心，主要关注数据安全周期的安全和合规性，以此来保护数据的安全。数据安全具有两层含义：一是**数据本身的安全**，主要是指采用现代密码算法对数据进行主动保护，如数据保密、数据完整性、双向强身份认证等，二是**数据防护的安全**，主要是采用现代信息存储手段对数据进行主动防护，如通过磁盘阵列、数据备份、异地容灾等手段保证数据的安全。

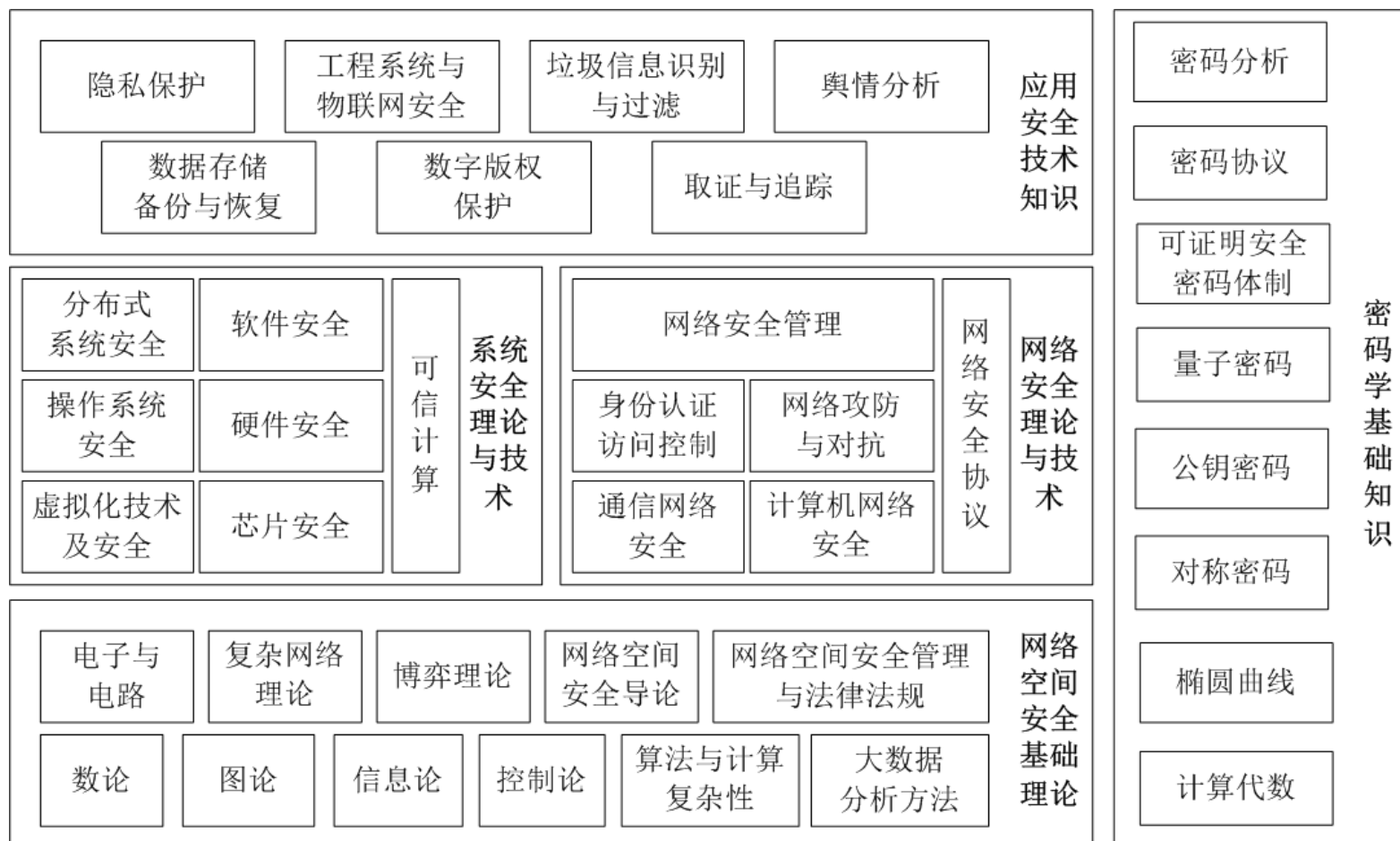
1 需要理解的几个关系

- ❑ 信息安全是指信息在生产、传输、处理和储存过程中不被泄漏或破坏，确保信息的可用性、保密性、完整性和不可否认性，并保证信息系统的可靠性和可控性。
- ❑ 信息不一定存在网络空间中，因此一切都有可能造成信息泄露、信息篡改等，除了常见的网络入侵窃密，还包括网络之外的场景，比如人性弱点的利用、间谍等造成的信息安全事件。
- ❑ 侧信道攻击（Side Channel Attack）

https://www.bilibili.com/video/BV1PT4y137cG/?spm_id_from=333.337.search-card.all.click&vd_source=4c1e046080d396b885383035c58cc631

- ❑ 社会工程学
https://www.bilibili.com/video/BV15V411u7Za/?spm_id_from=333.337.search-card.all.click&vd_source=4c1e046080d396b885383035c58cc631

1 信息安全知识体系



1 信息系统安全评估标准

□ 有关信息安全的国内外标准

➤ TCSEC

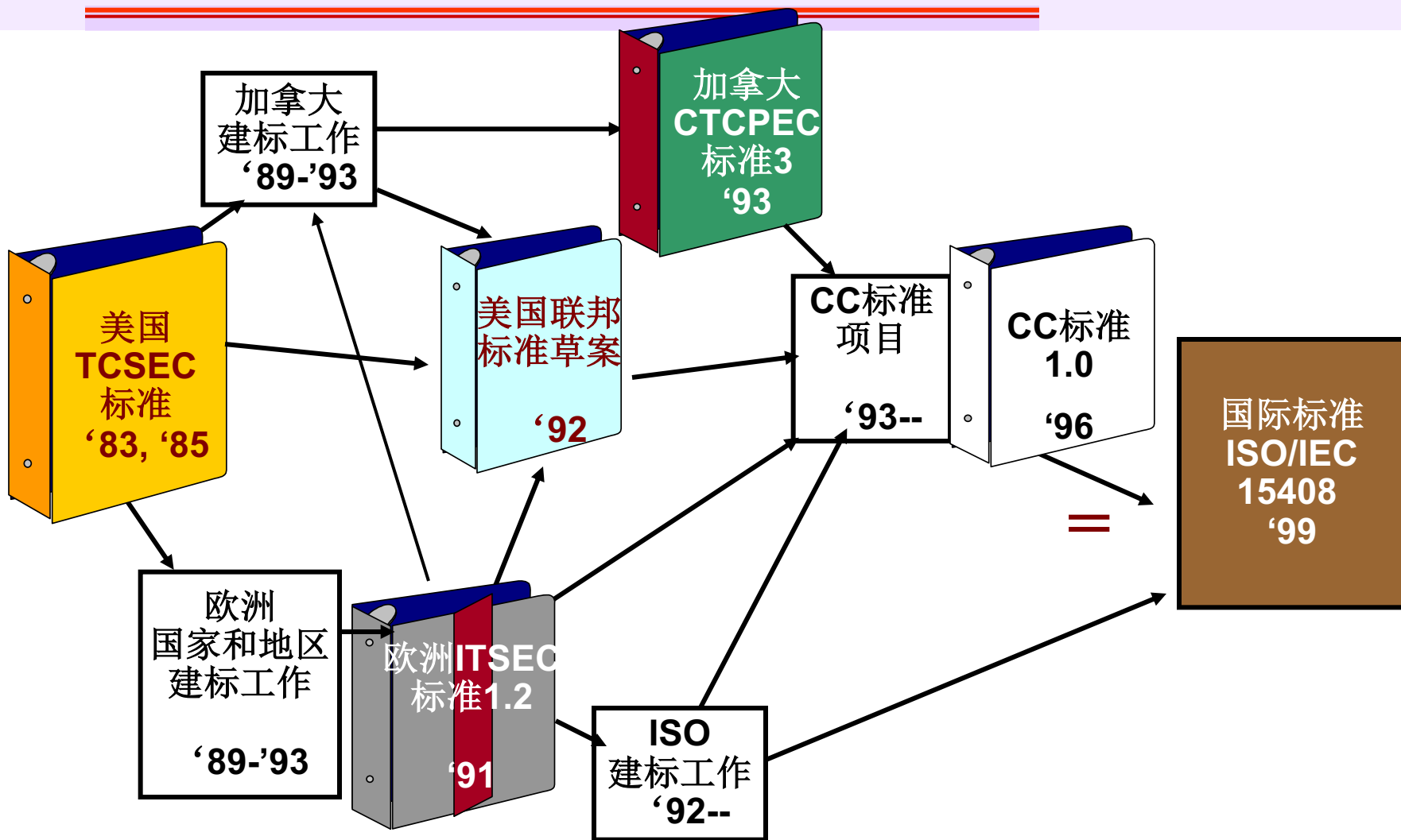
➤ CC

➤ ISO/IEC 15408-1

➤ BS 7799 / ISO 17799

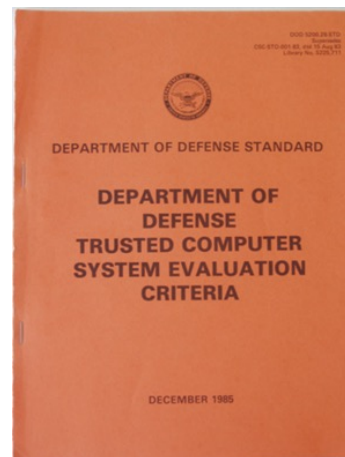
➤ 中国计算机安全等级划分

1 信息系统安全评估标准



1 信息系统安全评估标准

- ❑ 1985年，美国国防部颁布了全球第一个可信计算机评估准则（TCSEC），通常称为橘皮书。按照计算机系统的安全防护能力，分成4个等级共7个级别。TCSEC对后来的信息安全评估标准的建立起了重要参考作用。
- ❑ TCSEC将计算机系统的安全划分为四个等级、七个安全级别(从低到高依次为D1、C1、C2、B1、B2、B3和A1级)。
- ❑ 1996年，美国和欧洲联合提出了信息技术安全评估通用标准（CC for ITSEC）并成为国际标准ISO15408。CC对信息安全具有重要意义，是信息技术安全评价标准以及信息安全技术发展的一个重要里程碑。



1 信息系统安全评估标准

安全等级					主要特征	典型系统
1	D	最低保护等级	D	无安全保护	无访问控制	DOS、Windows 9x、Macintosh System 7.1。
2	C	自主保护等级	C1	自主安全保护	自主访问控制	UNIX、XENIX、Novell
			C2	可控访问保护	超C1的自主访问控制，审计功能	高版本的 Unix、Windows NT、Windows xp、Windows2000、Oracle
3	B	强制保护等级	B1	标记安全保护	强制访问控制，敏感度标记	OFS/1、Trusted Oracle、Incorporated INFORMAI- OnLine/Secure
			B2	可结构化保护	形式化模型，隐蔽通道约束	Trusted Xenix
			B3	安全区域保护	安全内核，高抗渗透能力	Honeywell Federal Systems XTS-200
4	A	验证保护等级	A1	可验证保护	形式化安全验证，隐蔽通道分析	Honeywell公司的SCOMP

举例1：零知识证明---数独游戏

	1	2	3	4	5	6	7	8	9
A							6	8	
B					7	3			9
C	3		9					4	5
D	4	9							
E	8		3		5		9		2
F								3	6
G	9	6					3		8
H	7			6	8				
I		2	8						

知乎 @吴寿鹤

- 问题：如何向其他人证明你已经解开数独游戏，并且不透露具体的数字摆放？

举例2：姚式百万富翁问题

- 问题：两个百万富翁都想比较到底谁更富有，但是有都不想让对方知道自己有多少钱。假定两人都值得信任，不会作假。那么，在没有可信的第三方的情况下如何比较？